ClearPay: Risk into Action

GRC / NIST CSF 2.0 gap analysis, risk register, and treatment roadmap

What I set out to do

I assessed a fictional payment business to show how information security risks can be translated into business priorities. The work starts with the assets, scores the risks, compares current practices with NIST CSF 2.0, and turns the gaps into actions with owners and target dates.

> **Scenario: ClearPay Solutions, a fictional 20-person fintech company using AWS, employee devices, source code repositories, vendor integrations, and an office network. This is a portfolio exercise, not an audit opinion or a statement about a real company.**

How the project works

Risk is scored as Likelihood (1–5) × Impact (1–5). The assessment uses the six NIST CSF 2.0 functions: Govern, Identify, Protect, Detect, Respond, and Recover. Findings should be validated with evidence before any real business relies on the scores.

Environment / scope

In scope: payment API, customer database, source-code repository, cloud storage, employee laptops, office network/Wi-Fi, employee email, and AWS identity/access management. Data includes customer personal information, payment tokens, transaction records, logs, and business documents.

Evidence and findings

The evidence for this project is documentary rather than a live SIEM alert. The supplied guide contains a fictional company scenario and sample findings. For a credible portfolio, attach sanitized configuration exports, screenshots, policy approvals, or test results that substantiate each statement; where no evidence exists, record the control as 'not evidenced' rather than 'failed' by assumption.

01 · Asset inventory

The starting inventory identifies eight assets and assigns an owner and criticality. In a real assessment, validate the list with system owners and cloud exports.

```
Sample asset: A-002 Customer Database (AWS RDS) | Data: PII and payment records | Owner: CISO |
Criticality: Critical
```

02 · Highest-priority risk

The example risk register scores missing MFA on database administrator accounts as likelihood 4 × impact 5 = 20, classified as Critical under the guide's scoring bands.

```
R-001 | Threat: unauthorized data access | Weakness: no MFA on database admin accounts | Score: 20/25 |
Treatment: enable MFA and enforce it through access policy
```

03 · NIST CSF 2.0 gap

The guide identifies high gaps in Govern, Identify, Protect, and Respond, with medium gaps in Detect and Recover. These ratings are scenario assumptions until evidence is reviewed.

```
Evidence to collect: approved security policy, asset inventory export, IAM/MFA configuration,
logging/alert settings, incident-response plan, backup restore test.
```

04 · Treatment tracking

A treatment register should show an accountable owner, deadline, status, and proof that the change worked. The example starts with MFA, public storage prevention, and least-privilege access.

```
Example action: R-001 | Owner: IT Admin | Target: 7 days | Evidence of closure: MFA enforcement
screenshot/export + successful access test + reviewer sign-off
```

What the evidence means

This project demonstrates the GRC workflow: identify what matters, explain what could go wrong, score risk consistently, identify framework gaps, and agree on actions that can be verified. A risk score is a prioritization aid, not a guarantee; business owners should approve risk acceptance and residual risk.

Recommended next steps

• Enable MFA on all critical cloud and database administrator accounts.

• Review IAM permissions and remove standing AdministratorAccess where it is not needed.

• Patch or migrate unsupported workloads and document exception approvals.

• Enable secret scanning and rotate any credentials found in source history.

• Block public S3 access by default and continuously check bucket configuration.

• Write and test incident-response and recovery procedures, including RTO/RPO targets.

• Assign owners, due dates, residual risk, and evidence of completion to every treatment action.

Priority risk register

Risk	Scenario weakness	Score	Treatment focus
R-001	No MFA on database admin accounts	20 · Critical	Enforce MFA; test access
R-003	No email security gateway or awareness training	16 · High	Email filtering and staff training
R-002	Unsupported / unpatched API workload	15 · High	Migrate to supported OS and patch
R-004	No secrets scanning in CI/CD	15 · High	Scan repositories; rotate exposed keys
R-005	Overly broad cloud IAM permissions	15 · High	Least privilege and access review
R-006	No automated public-bucket check	12 · Medium	Block public access and alert
R-008	No WAF / DDoS protection plan	10 · Medium	Assess API protection
R-007	Shared Wi-Fi password; no segmentation	8 · Medium	Separate networks and rotate access

Evidence integrity note

This portfolio document is based on the supplied project guide. The evidence snippets are illustrative lab examples or expected observations, not proof that a live system was tested by me. To present this as completed work, replace each example with a dated screenshot or exported log from your own lab, keep the original file, and record the tool version, host, timestamp, and test conditions.